

WIRELESS NETWORK AND IOT SECURITY

第三周：蜂窝通信安全

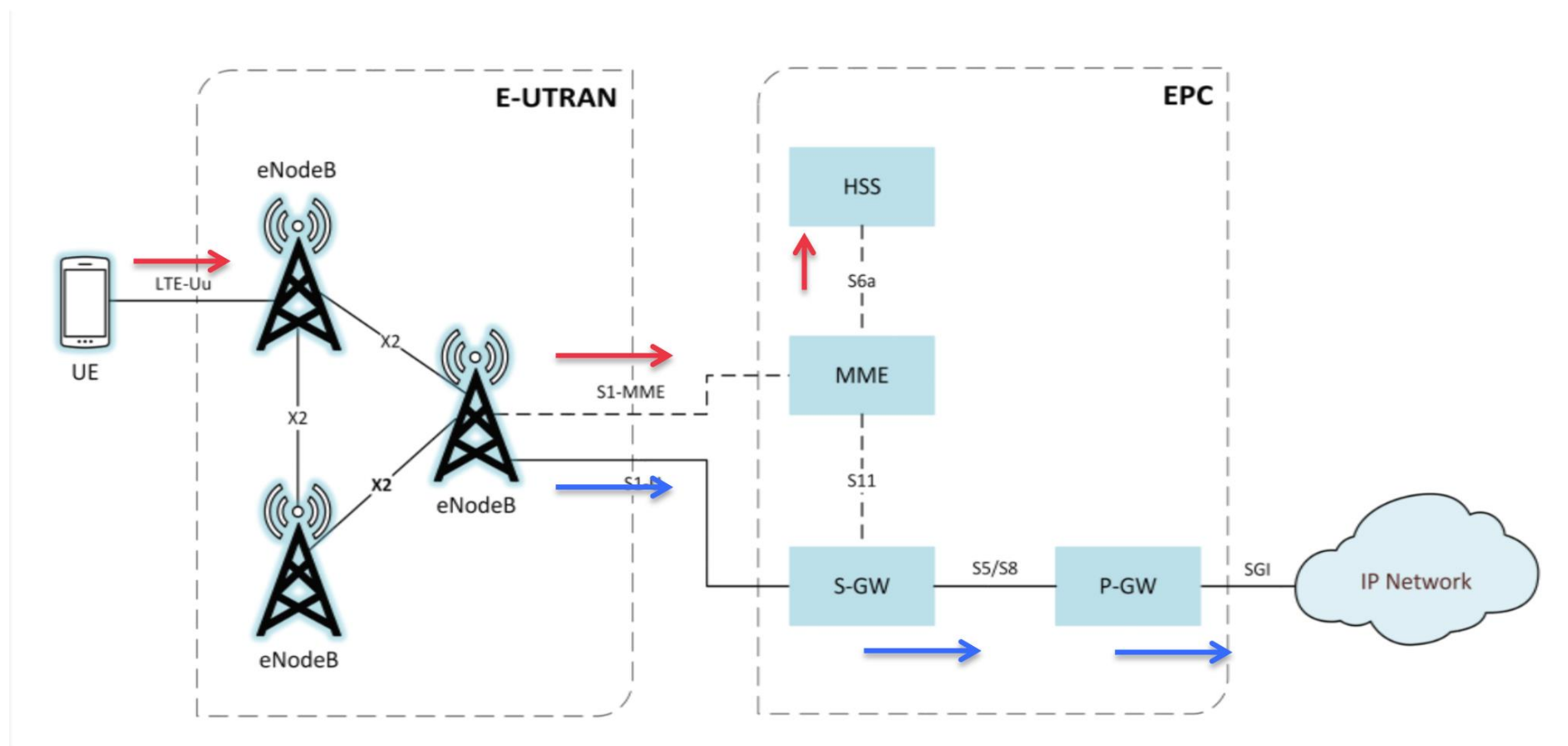


浙江大学
ZHEJIANG UNIVERSITY

What is 4G LTE

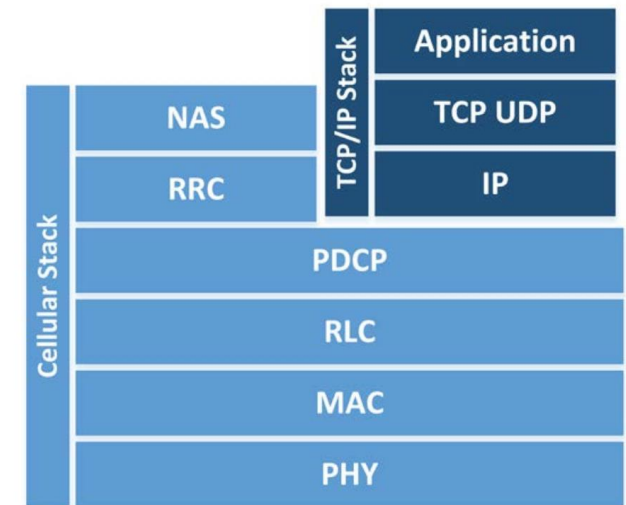
- LTE – Long Term Evolution
- Evolutionary step from GSM to UMTS
- 4th generation cellular technology standard from the 3rd Generation Partnership Project (3GPP)
- Deployed worldwide and installations are rapidly increasing
- LTE is completely packet-switched
- Technology to provide increased data rates

LTE Network



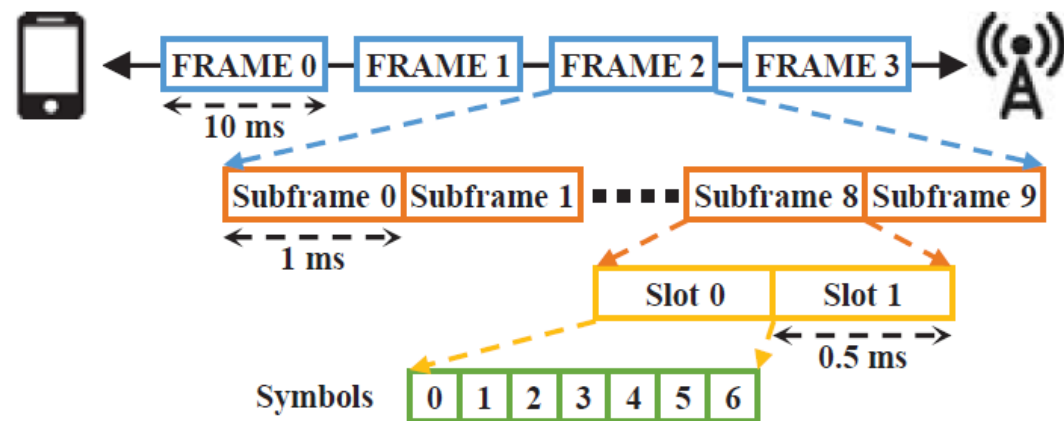
LTE Network Protocols

- The following protocols are used for communication over the air interface (the radio link between the UE and the eNodeB). This protocol suite is generally divided into three layers:
- Radio Resource Control (RRC) operating at layer 3;
- Packet Data Convergence Protocol (PDCP) operating at layer 2;
- Radio Link Control (RLC) operating at layer 2;
- Medium Access Control (MAC) operating at layer 2;
- Physical Access (PHY) operating at layer 1.



LTE帧结构

1 帧 (10 ms)
= 10 子帧
= 10 * 2 时隙
= 10 * 2 * 7 OFDM Symbols



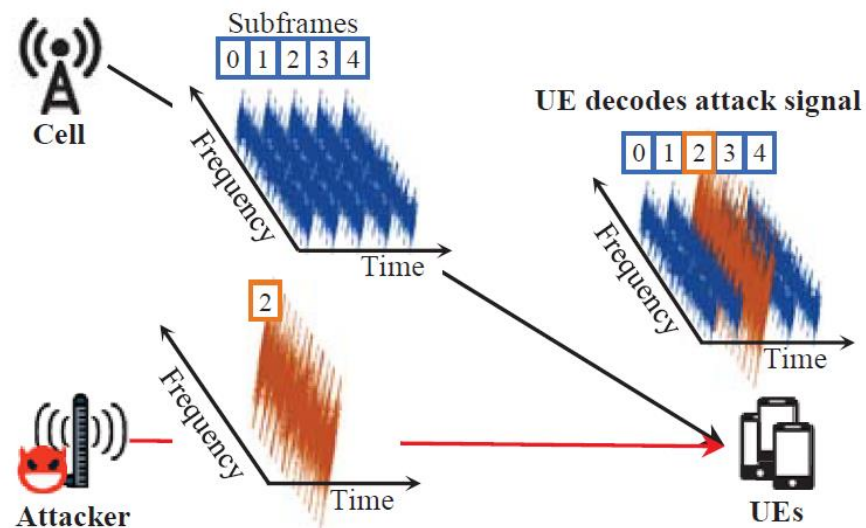
一种典型的LTE帧结构

信号遮蔽攻击（Signal Overshadowing Attack）

信号捕捉效应（Capture Effect）：当空中同时存在多个无线信号时，功率**最强**的那个信号会被接收方解调出来。

信号遮蔽攻击（SigOver Attack）：攻击者发送信号对目标子帧进行精准遮蔽（时域和频域上对齐）

- 若攻击信号无实际意义：Jamming
- 若攻击信号是**攻击者伪造的子帧**：攻击者能够向受害者注入伪造的（广播）信息



LTE信号遮蔽攻击示意图

攻击模型

- 攻击者不需要知道受害者UE的密钥（受害者与基站之间的加密传输无法被解密）
- 攻击者能够监听合法基站到受害者UE的广播信息

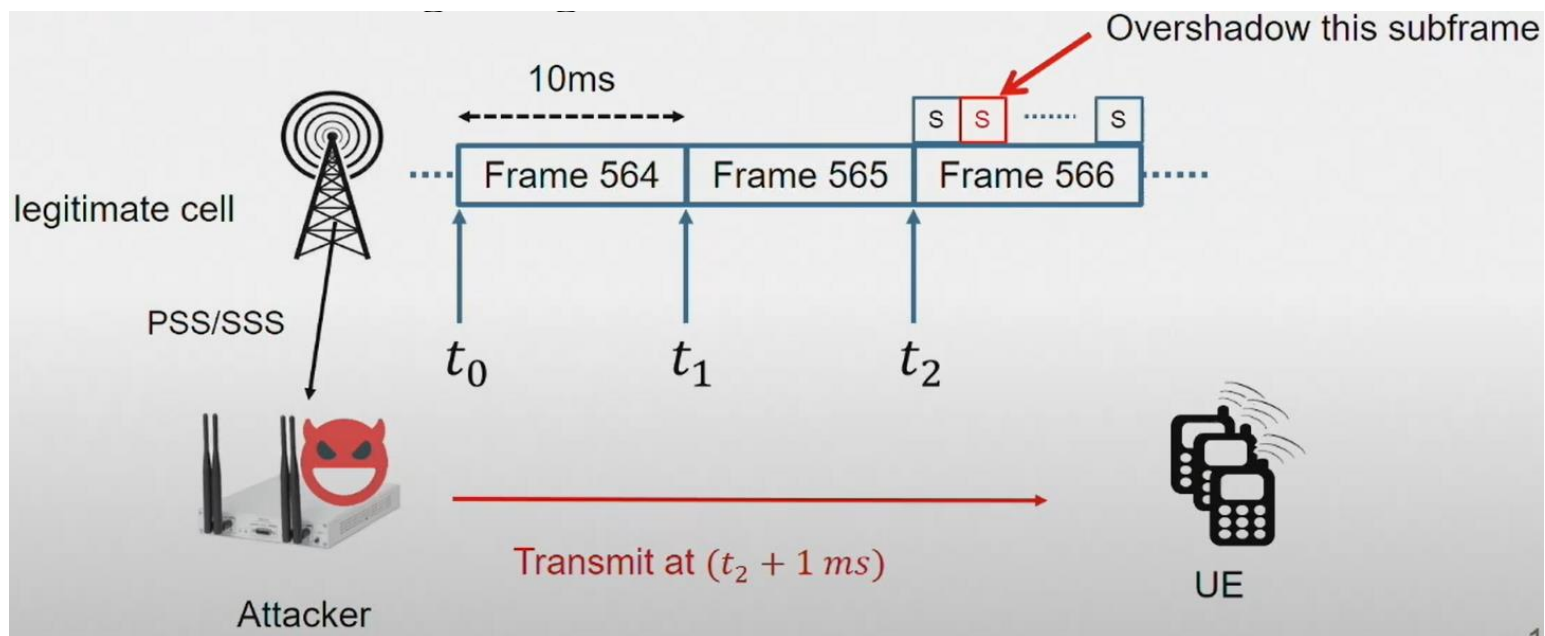


构造恶意子帧

- 通信配置的匹配
 - 识别受害者所接入合法基站的物理配置信息
 - 通过监听可完成
- 构造的子帧
 - 恶意信息
 - 符合LTE标准——由多种LTE channel组成 (PCFICH, PDCCH, PDSCH)
 - 导频信号 (Pilot signal)
 - 通过包含导频信号来帮助受害者成功解调出恶意子帧中的信息

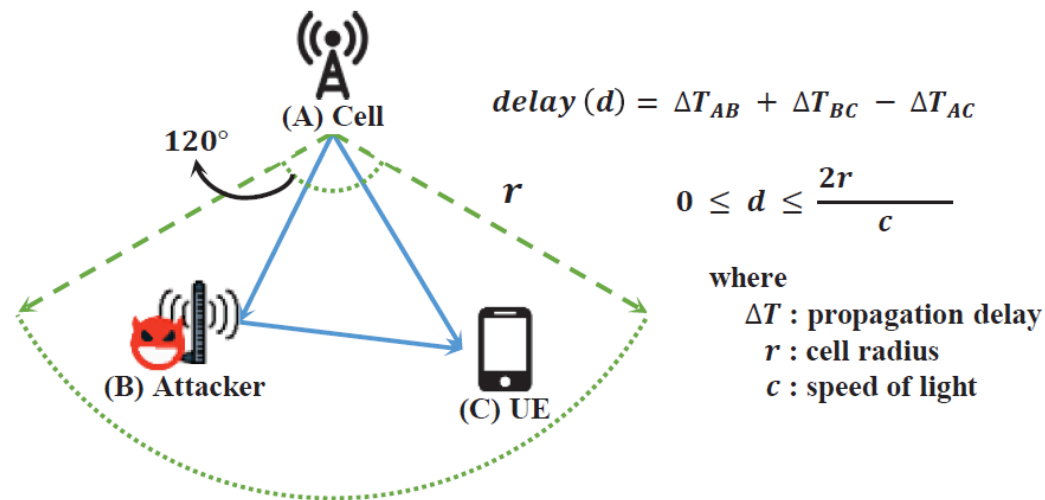
精确的信号遮蔽 (SigOver)

- 时域上的同步
 - LTE的子帧有严格的时间顺序
 - 使用合法基站的同步信号 (PSS/SSS) 完成时域上的同步
 - 确定合法基站的帧/子帧的时序



精确的信号遮蔽（SigOver）

- 时域同步的问题：传输时延无法避免
 - 攻击者发送的信号存在时延，它随着攻击者、基站、受害者三者位置的不同而改变
 - 解决方案：手机的基带处理器本身有一定的延迟容忍度
 - 对于一个典型的覆盖半径为1.5km的基站而言，攻击者最大时延为10 μ s.



无法避免的传输时延

Time (μ s)	LG G7 (Qualcomm)	Galaxy S9 (Exynos)
Max. tolerance*	12.7	11.06

手机所能容忍的时延

10

精确的信号遮蔽 (SigOver)

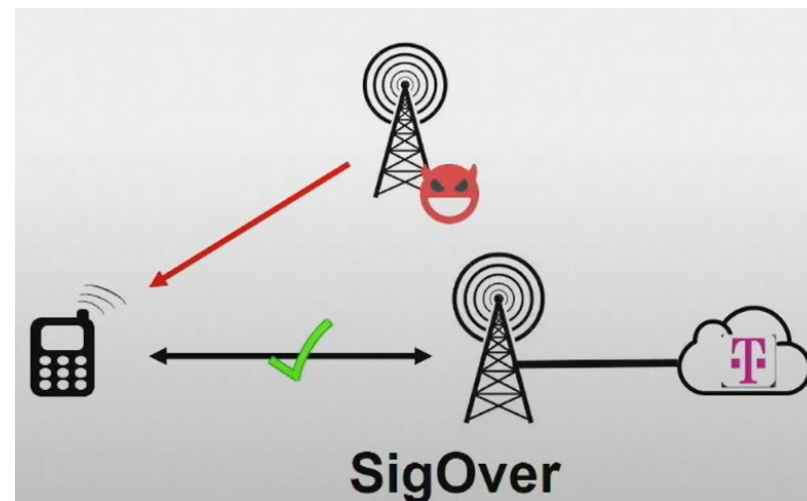
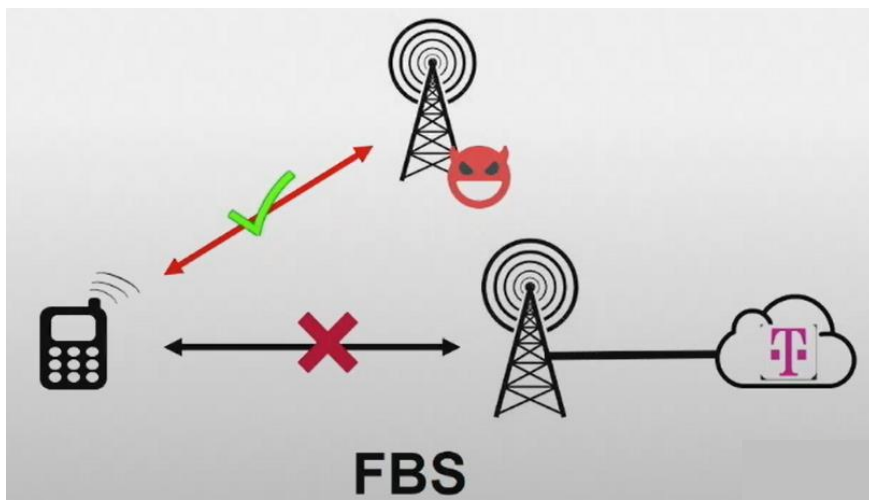
- 频域同步
 - LTE标准规定了基站最小的频率精度
 - 十亿分之50的偏差 ($\pm 90\text{Hz}$ @1.8GHz)
 - 使用GPS定向振荡器
 - 十亿分之25的偏差 ($\pm 45\text{Hz}$ @1.8GHz)



GPSDO

伪基站（FBS）vs. 信号遮蔽（SigOver）

- FBS和SigOver都能够向UE发送广播信息
- SigOver 的优势
 - 功率优势
 - 不需要与基站建立连接
 - 受害者UE与合法基站保持通信



实际攻击效果

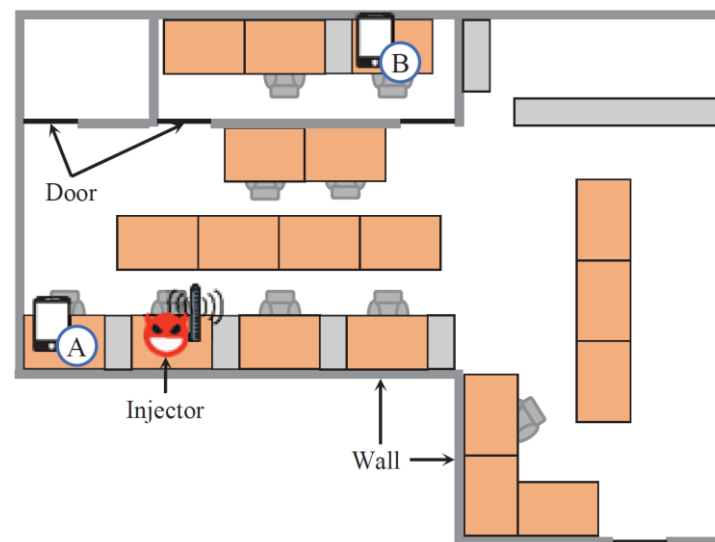
- 功率的优势

Relative Power (dB)	1	3	5	7	9
SigOver	38%	98%	100%	100%	98%
Relative Power (dB)	25	30	35	40	45
FBS attack	0%	0%	80%	100%	100%

信号遮蔽 (SigOver) 与伪基站 (FBS) 攻击的成功率对比

- 攻击鲁棒性

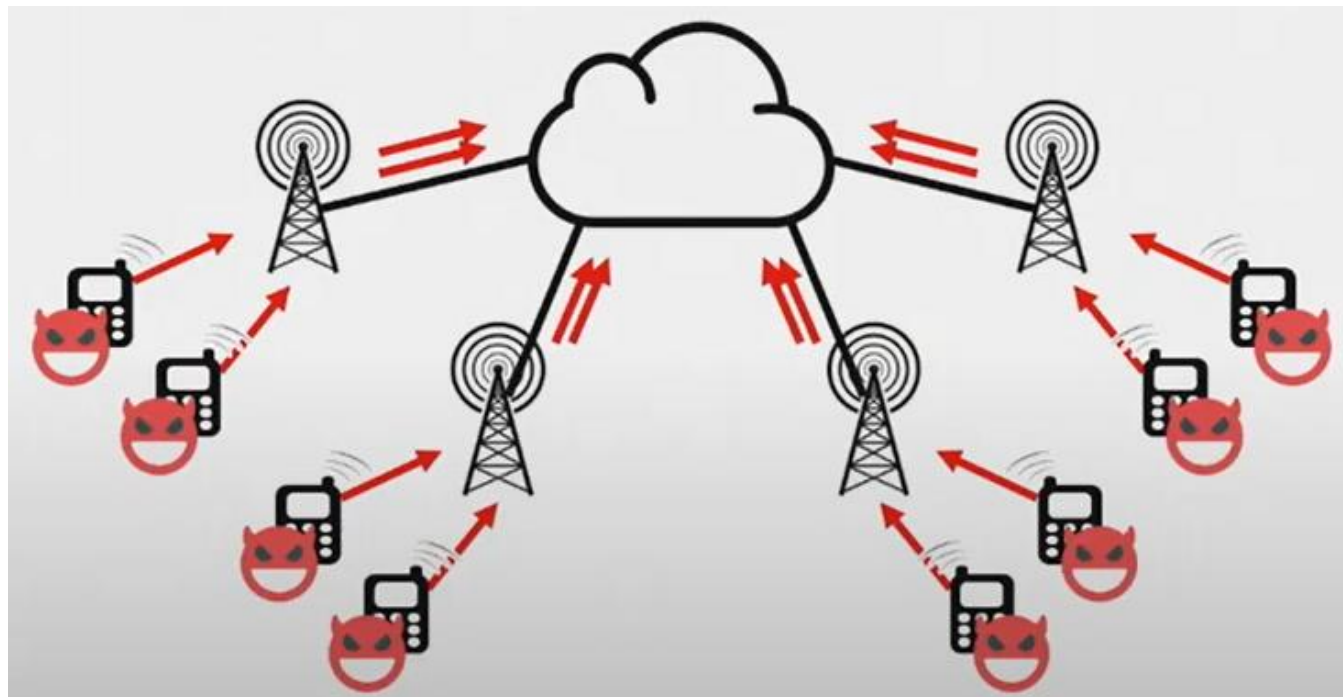
	LOS	NLOS
<i>RRC Connected</i>	97%	98%
<i>RRC Idle</i>	100%	98%



鲁棒性测试的环境
(A) LOS (2m) (B) NLOS (10m)

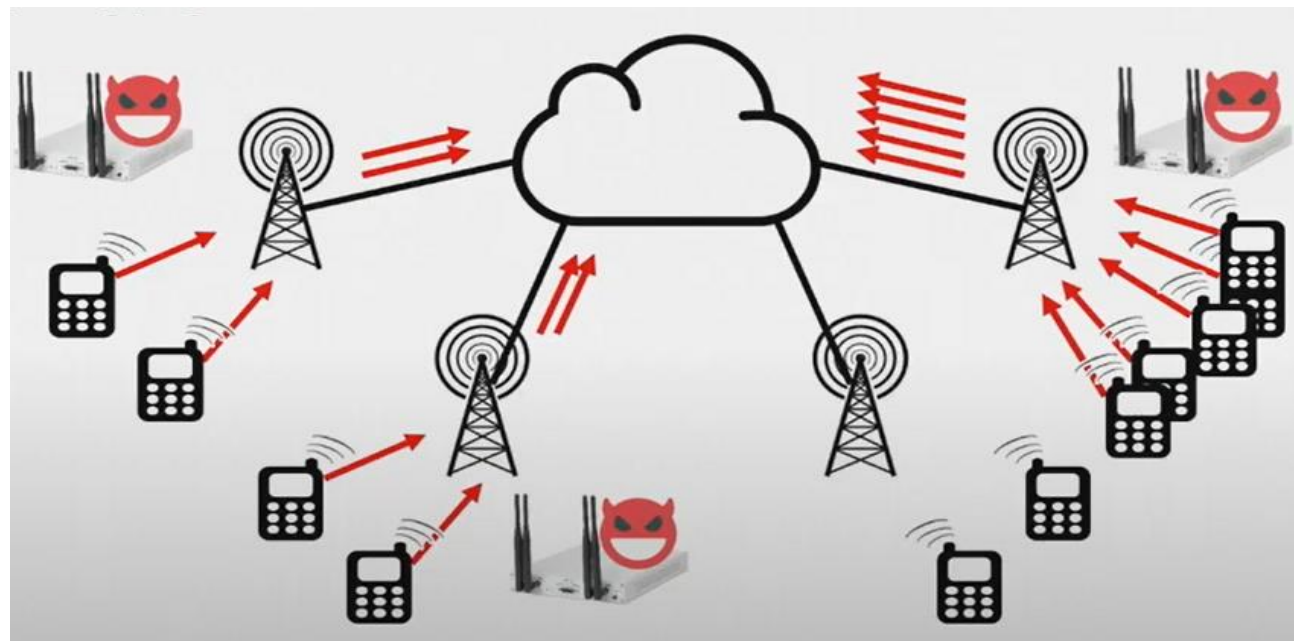
SigOver攻击应用——信令风暴

- 常规的信令风暴攻击
 - 需要大量的恶意设备 (DDoS)



SigOver攻击应用——信令风暴

- SigOver实现信令攻击
 - 通过伪造的子帧触使受害者UE与基站进行交互
 - 可以对一个基站下所有UE进行攻击

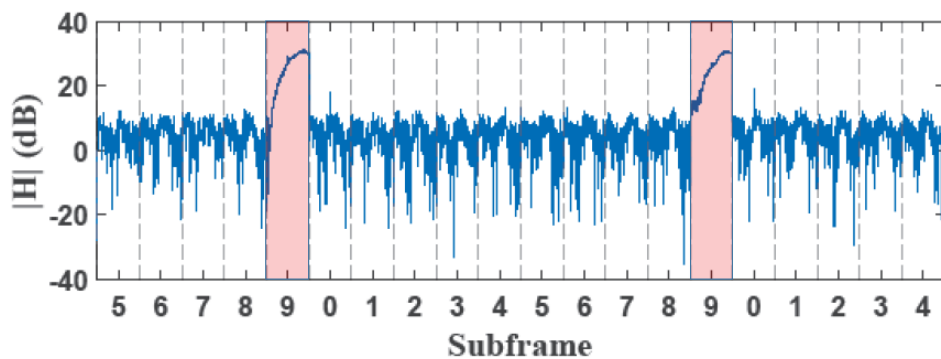


攻击效率

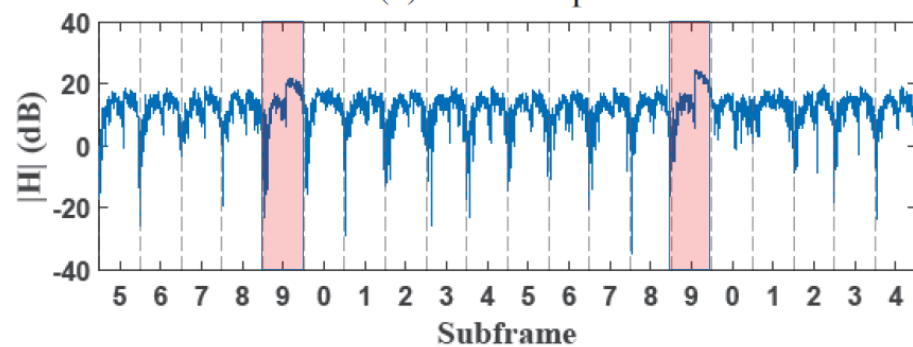
- 设备正常使用
 - 在高峰期平均每台设备每个小时有45次位置更新的服务请求
- SigOver
 - 每台UE每个小时21600次位置更新请求
- 所有的信令
 - 正常使用：一台UE每小时675次
 - SigOver：一台UE每小时432000次（正常使用的640倍）

防御措施

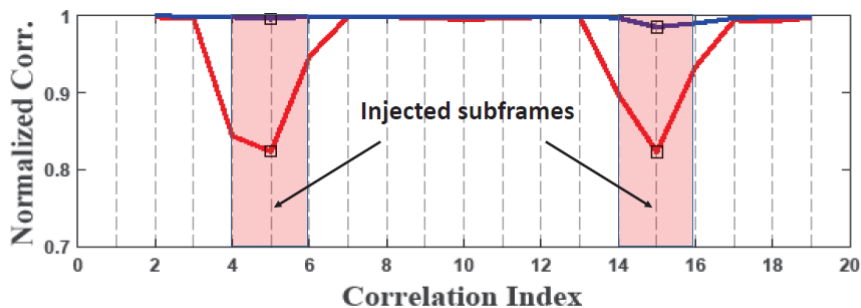
- 检测SigOver攻击
 - 利用信道的不同
 - 问题：鲁棒性还需提升，NLOS下难以实现区分



(a) LOS setup



(b) NLOS setup



(c) Normalized cross-correlation on LOS (Red line) and NLOS (Blue line)

防御措施

- 对广播信息进行数字签名
 - 部署存在挑战
 - 对于全球漫游场景，需要一个全球的公钥体制
 - 管理证书需要额外开销
 - 技术上的挑战
 - 广播信息周期很低（如 40/80ms）
 - 认证证书和签名会导致UE设备更高的电量开销

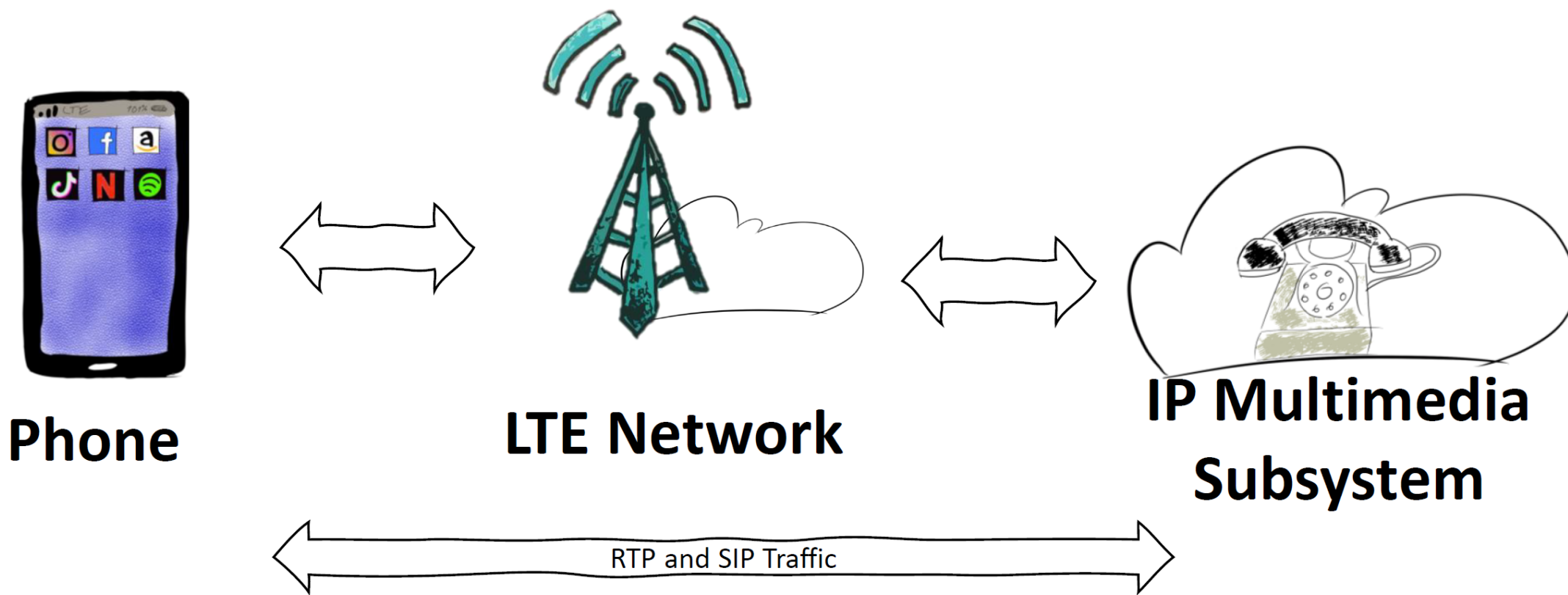
第二种攻击——针对VoLTE的攻击

- 全球有**253**家运营商在使用VoLTE（手机上的“VoLTE”图标或者“HD”图标）
- VoLTE
 - 即通过4G流量进行语音通话
- VoLTE的优势
 - 核心网处理时间更快
 - 更高清高质量的通话
 - 对于运营商而言使用VoLTE更有效率



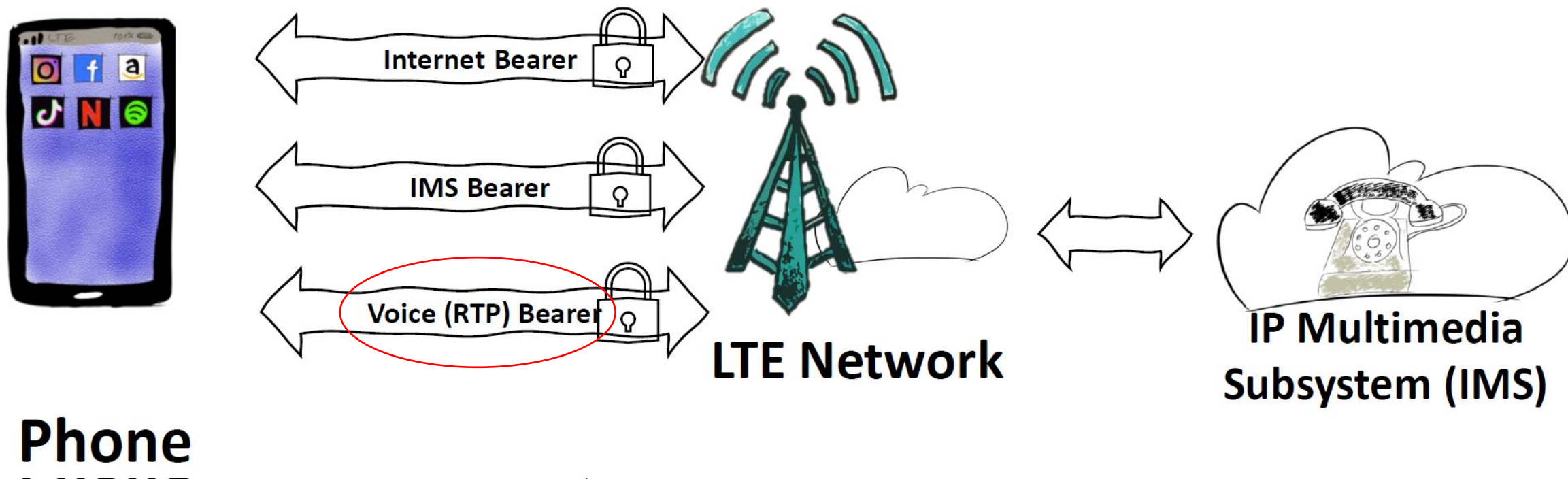
VoLTE介绍

- UE与IP 多媒体子系统（IMS）建立联系，IMS管理VoLTE的呼入/呼出

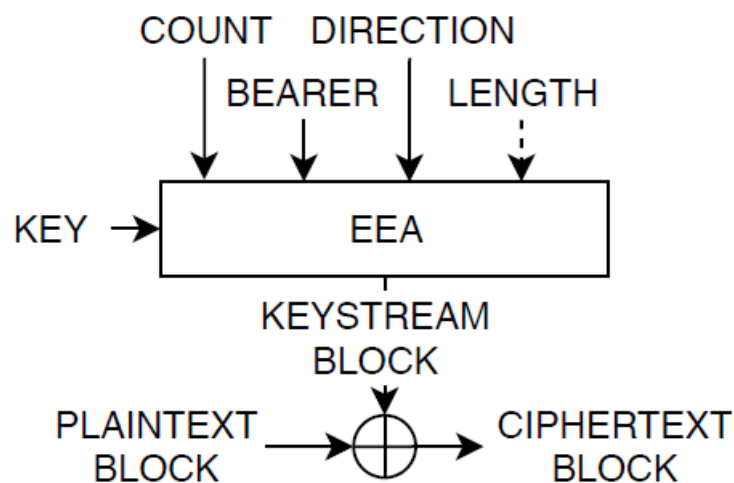


VoLTE的承载（Bearer）

- 承载（Bearer）：指核心网到UE的逻辑通路



LTE的流加密



LTE的流加密

Key : 用于VoLTE的密钥，每次建立无线电连接时会产生一个新的密钥

Count : 数据包的序列号

Bearer : 目前加密所用于的承载

Direction : 上行或下行

Length : 流密钥块的长度，不会影响密钥生成

EEA : EPS 加密算法

$$(\text{Plaintext A} \oplus \text{Keystream}) \oplus (\text{Plaintext B} \oplus \text{Keystream}) = (\text{Plaintext A} \oplus \text{Plaintext B})$$

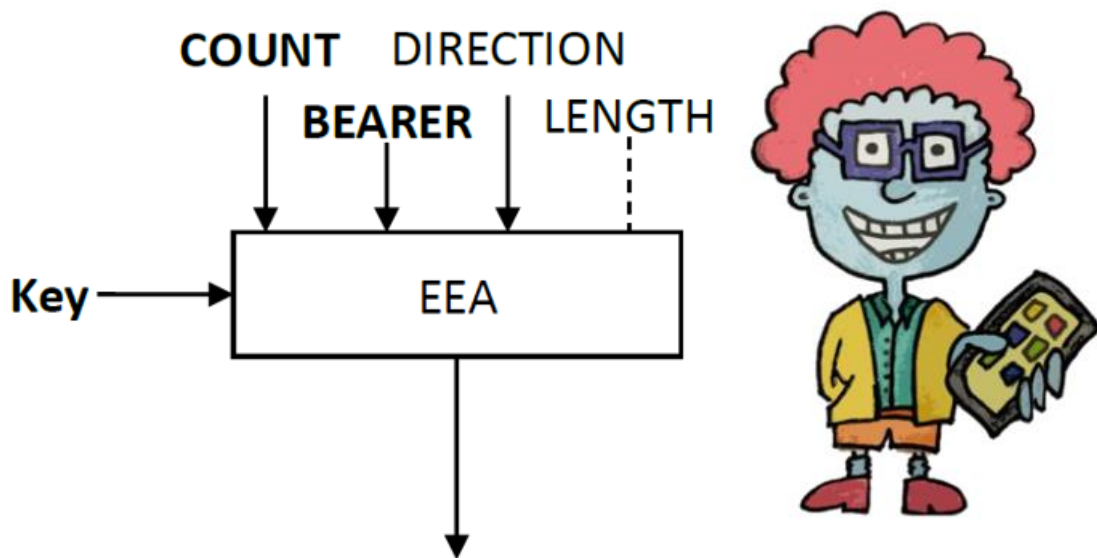
$$(\text{ Plaintext A } \oplus \text{ Plaintext B }) \oplus \text{ Plaintext B } = \text{ Plaintext A }$$

密钥重用会导致密文被解密

- **ReVoLTE** : 重用加密的VoLTE流量来监听通话

VoLTE中的密钥重用

- 开始通话前，VoLTE会建立加密链路，并生成密钥Key

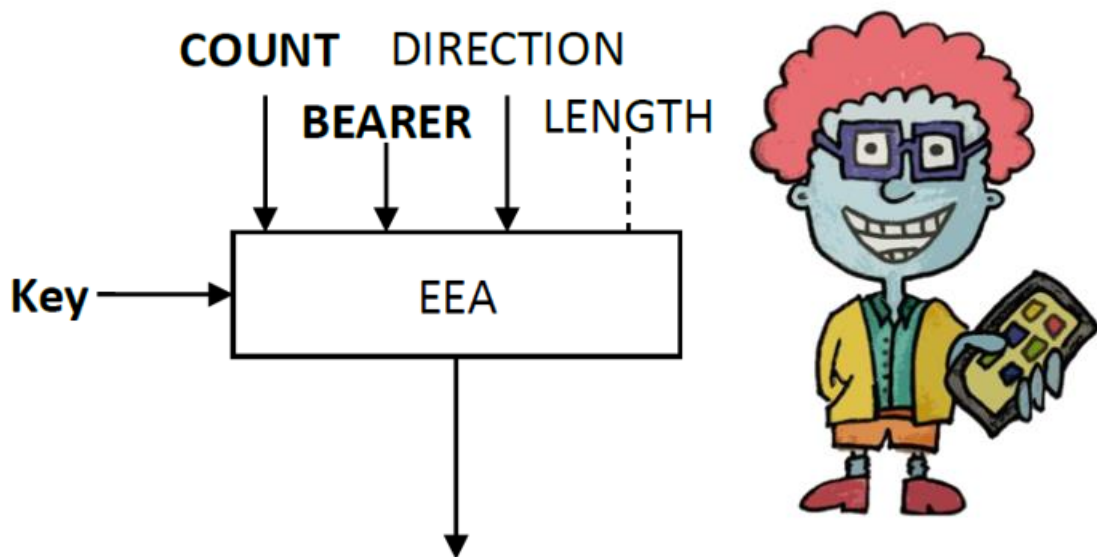


1. RRC Security Mode Command
← Key (k_{up}) →



VoLTE中的密钥重用

- 用户拨打第一个电话后，VoLTE重置COUNT，设置好BEARER



1. RRC Security Mode Command
Key (k_{up})

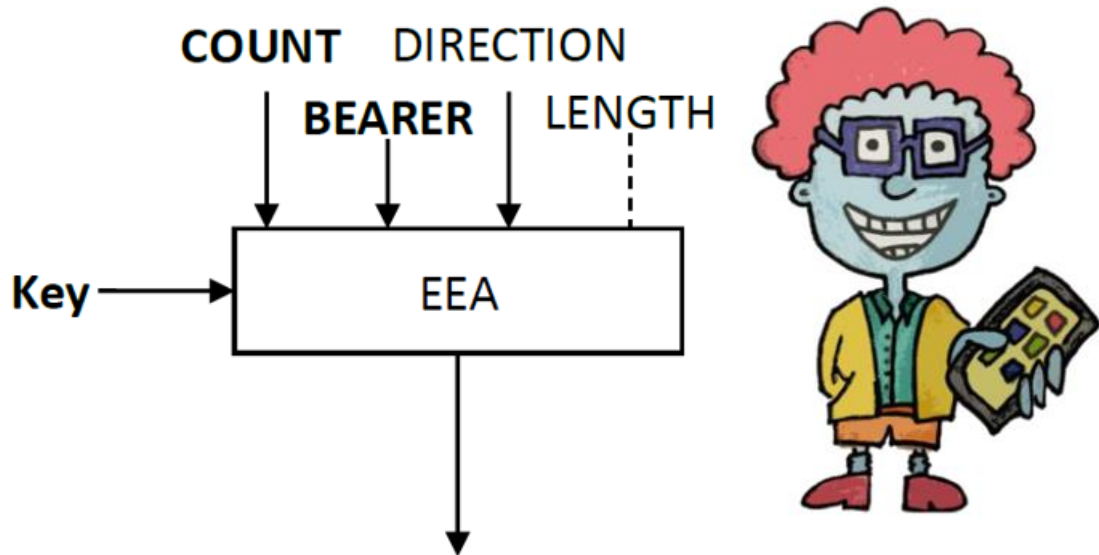
First Call

Resets **COUNT**, Sets **BEARER ID**



VoLTE中的密钥重用

- 用户拨打第二个电话后，VoLTE再次重置COUNT，设置好BEARER



1. RRC Security Mode Command
Key (k_{up})

First Call

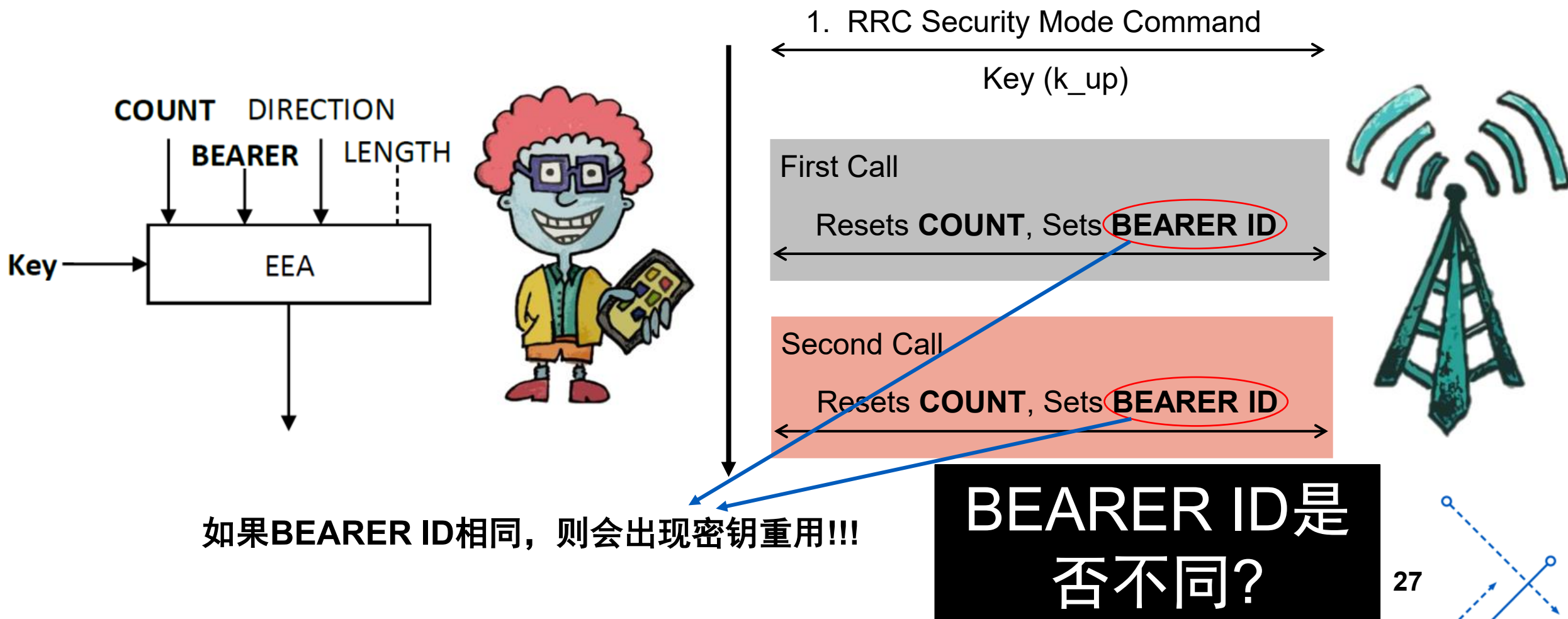
Resets **COUNT**, Sets **BEARER ID**

Second Call

Resets **COUNT**, Sets **BEARER ID**



VoLTE中的密钥重用



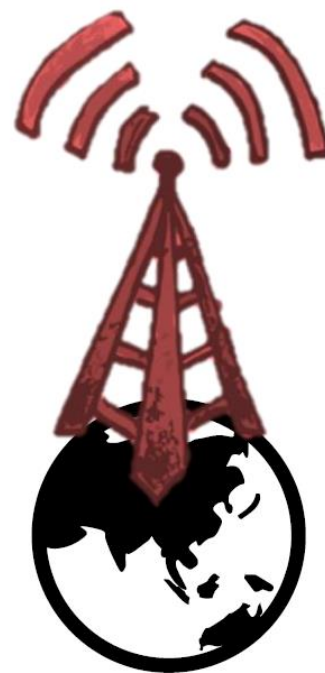
不安全的基站

3 / 15

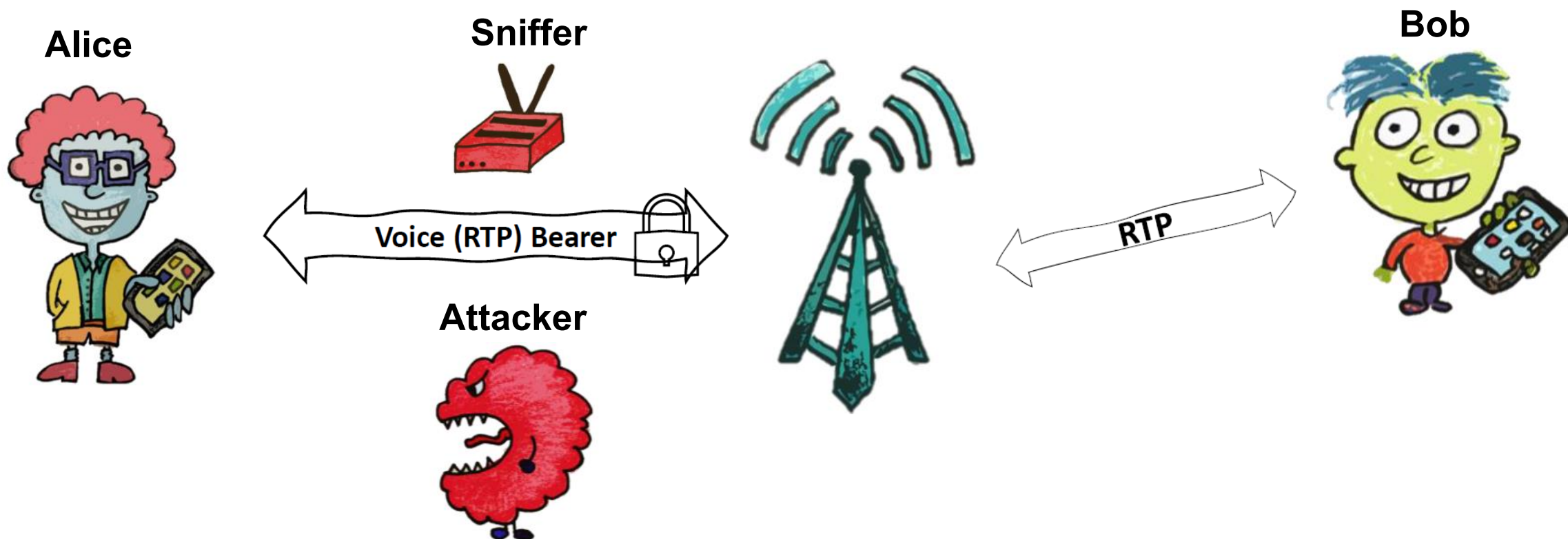
基站会增加Bearer ID的值

12 / 15

基站出现了**密钥重用**



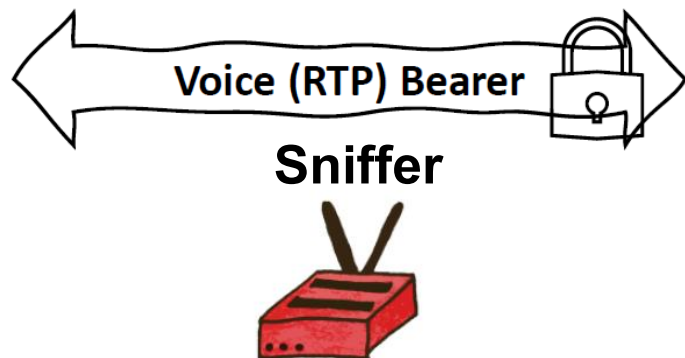
ReVoLTE 攻击流程



1. 目标通话 (第一次通话): 攻击者嗅探目标通话的密文 (c)

ReVoLTE Attack Procedure

Alice



Attacker



2. 密钥通话 (第二次通话): 攻击者在发现上一个通话结束后, 立即进行发起第二次通话, 攻击者收集通话过程中的明文 (m') 和密文 (c')。结合第一步的密文 (c), 即可推导出目标通话的明文

实际的REVOLTE

- 实验使用了3台UE，一个连接了USRP B210的笔记本（用于下行链路的嗅探和攻击的实现）
- 结果
 - 解密了89% 的数据包
 - 信息损失的原因：下行链路的嗅探没能捕捉到所有的无线数据包（在目标通话中损失了3%，在密钥通话中损失了 8%

Role	Phone	OS v.	Provider
Calling Partner	OnePlus 6T	9.0	P01
Attacker	Xiaomi Pocophone F1	9.0	P03
Victim	Sony Xperia X	8.0	P03

手机配置

漏洞分析

- 总结：在UE与基站保持连接下连续进行两次通话时，COUNT会被重置，Bearer ID的重用会导致最终密钥的重用
- 实现上的缺陷
- VoLTE的规范模棱两可：禁止重复使用密钥流，但并没有指定一个确切的实现方式

防御措施

- 在不同通话中使用不同的Bearer ID
- 加密RTP流量

